SK Shieldus Rookies

경영진 보고

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

전체 위험 수준	진단 일자	문서 번호	작성
심각	2026-10-02	SCAN-2026-003-E	SK쉴더스 루키즈 34기 1석삼조 팀

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

로그인 페이지 주석에 테스트 계정 정보가 노출되었습니다

러닝브릿지의 온라인 교육 플랫폼에서 로그인 페이지 주석에 테스트 계정 정보가 노출되어 120,000명의 개인정보가 위험에 처해 있습니다. 공격자가 이 정보를 이용해 시스템에 접근할 경우, 수강 이력과 같은 민감한 정보가 유출될 수 있습니다.

전체 위험 수준

심각

개인정보를 처리하는 자산에 '상' 위험 취약점이 있음

취약 항목

2 건 / 점검 3개 항목

상 1건, 중 1건, 하 0건

영향받는 개인정보 처리 자산

1 개

웹 서비스 (localhost:5000)

핵심 위험

1 로그인 페이지 주석에 계정 정보 노출로 인한 개인정보 유출 위험 상

외부인이 테스트 계정 정보를 통해 시스템에 접근할 수 있어, 개인정보 유출 및 서비스 신뢰도 하락이 우려됩니다.

관련 법령 개인정보 보호법 제29조(안전조치의무) 검토 전
관련 법령 개인정보의 안전성 확보조치 기준 제5조 제4항, 제5항(접근 권한의 관리) 검토 전
관련 법령 개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제) 검토 전
유사 사례 대구가톨릭대학교 · 권한 확인 누락, 개인정보 노출 동일 결함 **과태료 360만 원**
유사 사례 (주)케이에스한국고용정보 · 파라미터 변조, 관리자 페이지 노출 동일 결함 **과징금 35억 3,700만 원, 과태료 420만 원, 공표명령**

2 에러페이지에서 서버 정보 노출로 인한 보안 위험 중

공격자가 서버 내부 정보를 악용하여 추가적인 공격을 시도할 수 있어, 서비스 중단 및 데이터 유출 위험이 있습니다.

유사 사례 대구한의대학교 · 권한 확인 누락, 개인정보 노출 동일 결함 **과태료 360만 원**
유사 사례 강북구청 · 관리자 페이지 노출, 보안 패치 미적용 동일 결함 **과징금 3억 7,800만 원, 과태료 480만 원, 공표명령**

관련 법령과 인증기준

조항·기준	관련 취약점	상태
개인정보 보호법 제29조(안전조치의무)	1건	검토 전
개인정보의 안전성 확보조치 기준 제5조 제4항, 제5항(접근 권한의 관리)	1건	검토 전
개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제)	1건	검토 전
ISMS-P 2.5.1 사용자 계정 관리	1건	검토 전
ISMS-P 2.6.3 응용프로그램 접근	1건	검토 전
ISMS-P 2.10.3 공개서버 보안	1건	검토 전

'검토 전'은 AI가 매핑하고 담당자가 아직 확인하지 않은 항목입니다. 확정 전까지는 위반 소지로 보아야 합니다.
사례 등급: 동일 결함 = 인증기준과 취약점 유형이 모두 같음, 같은 유형 = 취약점 유형이 같음, 관련 통제 = 인증기준만 같음.

유사 처분·보도 사례

과징금 처분 개인정보위 2023-10-12 동일 결함
대구가톨릭대학교 · 권한 확인 누락, 개인정보 노출
과태료 360만 원

과징금 처분 개인정보위 2026-04-23 동일 결함
(주)케이에스한국고용정보 · 파라미터 변조, 관리자 페이지 노출
과징금 35억 3,700만 원, 과태료 420만 원, 공표명령

과징금 처분 개인정보위 2023-10-12 동일 결함
대구한의대학교 · 권한 확인 누락, 개인정보 노출
과태료 360만 원

과징금 처분 개인정보위 2026-03-26 동일 결함
강북구청 · 관리자 페이지 노출, 보안 패치 미적용
과징금 3억 7,800만 원, 과태료 480만 원, 공표명령

과징금 노출과 감경 여지

최대 노출액 (법정 상한)

1억 5,000만 원

연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 1건 해당

투자 감경 반영 시 (예시)

9,000만 원

보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음

10% 특례 시나리오

5억 원

반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

같은 유형 결함의 실제 과징금

유사 처분 6건 · 최소 329만 원 · 중앙값 20억 3,550만 원 · 최대 151억 4,196만 원

사례	처분일	과징금
(주)카카오 · 개인정보 노출, 보안 패치 미적용 동일 결함	2024-05-23	**151억 4,196만 원**
(주)골프존 · 권한 확인 누락, 개인정보 노출 동일 결함	2024-05-09	**75억 400만 원**
(주)티머니 · 크리덴셜 스터핑, 이상행위 탐지 미흡 같은 유형	2026-01-29	**5억 3,400만 원**
현대자동차(주) · 보안 패치 미적용, 개인정보 노출 같은 유형	2024-08-28	**329만 원**

법정 상한은 최대치이며 예상 부과액이 아닙니다. 실제 부과액은 과징금 부과기준의 산정 단계(기준금액, 감경, 조정)를 거쳐 정해집니다.
유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.

조치 로드맵

즉시 1주 이내

로그인 페이지 주석 내 테스트 계정 정보 삭제

주석 내 정보 누출

단기 1개월 이내

에러페이지 정보 노출 방지를 위한 서버 설정 변경

에러페이지 정보 노출

중기 분기 이내

해당 없음

경영진 결정이 필요한 사항

1 로그인 페이지 주석 내 정보 삭제 작업을 이번 주말까지 완료해 주십시오.

2 보안 투자 기록 관리를 위해 관련 조치 및 투자 내역을 체계적으로 기록해 주십시오.

취약점별 상세 내용과 조치 방법은 실무진용 상세 보고서(SCAN-2026-003-T)에 있습니다. 법령·인증기준 매핑 중 6건은 아직 담당자 검토 전입니다.